MedAnon: context-aware anonymization of doctor–patient encounters

Bosch challenge "Anonymization of patient data" · Neural Wave Hackathon 2026
Matteo Marello · Paolo Pusterla · Tommaso Riggio · Andrea Orione · Valeria Intini
Code and evidence: `https://github.com/neural-wave/ch-Fuma-c-anduma`

1 The problem

Hospitals want to use clinical text with cloud-hosted language models, so it must first be anonymized without losing its medical value. Each encounter is a JSONL record with a doctor–patient `dialogue` (lowercase speech-recognition text), a clinical `note` and its `icd10_codes`, which must be preserved. Bosch weighs privacy protection, preserved medical information, and originality and scalability equally; inference must run on-premise within 4 GB of VRAM. Three properties of the data make naive masking fail:

- **The dialogue has no capital letters.** "hey ray , good to see you" defeats capitalization-based NER, and numbers are spoken ("one thirty two over eighty four").
- **Medicine is full of words that look like people.** Eponyms (Cushing's, Parkinson's), drug brands, tests and scores. A generic PII tool masks them and the note loses its meaning.
- **Records identify people without names.** Age, sex, town, employer, family size and an unusual history can single a person out after every name is gone.

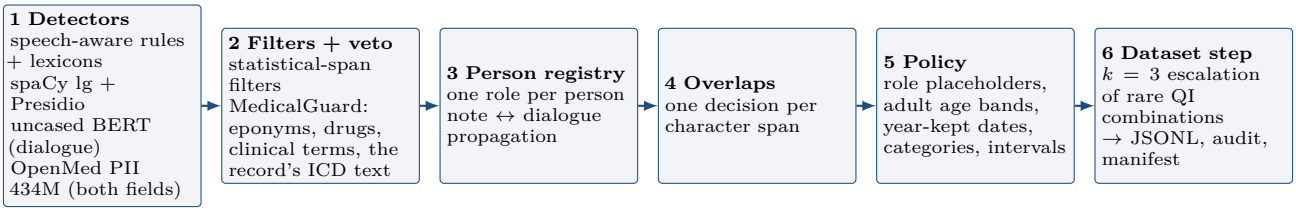
2 Approach

MedAnon is a deterministic pipeline over character spans. Detectors only *propose* spans, a clinical guard can veto them, and a policy decides how each surviving span is rewritten. No generative model rewrites the text, so nothing outside the replaced spans changes, nothing can be hallucinated, and every decision is logged with its reason. Nothing was fine-tuned: the system combines pretrained NER models, rules and public lexicons.

Information	**Release policy** (`configs/age_bands.yaml`, the built-in default)
Names	role placeholders, consistent across note and dialogue: `[PATIENT_NAME]`, `[CLINICIAN_NAME]`, `[RELATIVE_NAME]`
Age	adult decade band `[40-49]`; exact under 18; `90+`
Dates	day and month removed, year kept (`[DATE] 2024`); adult birth years removed
Places, organisations	`[CITY]`, `[US_STATE]`, `[EMPLOYER]`, `[HEALTHCARE_FACILITY]`; countries become a world region
Occupation, labs, body measures	category (`[OCCUPATION: service]`); clinical interval (A1c 8.0 → `[8-9]`); weight and height generalized unless needed exactly
Kept	diagnoses, drugs, doses, vital signs, durations, relative times; `icd10_codes` byte-identical

Fictional example (`medanon demo`): "Ray Cushing is a 46-year-old male with … cushing's syndrome … works as a cashier at Boeing" becomes "`[PATIENT_NAME]` is a `[40-49]`-year-old male with … cushing's syndrome … works as a `[OCCUPATION: service]` at `[EMPLOYER]`". Following the task's rule, diagnosis-relevant details that do not affect the ICD-10 code (exact lab values, body measures) are generalized when they could link records.

Why these components. *Rules and lexicons* handle what models miss in lowercase speech: vocatives, spoken numbers, IDs, dictation openers, and a name-dominance ratio (Census/SSA name frequency against English word frequency). *spaCy `en_core_web_lg` with Presidio patterns* runs on the note and on a note-guided truecased view of the dialogue. *`dslim/bert-base-NER-uncased`* runs as a cascade on the dialogue: in our comparison it matched GLiNER-PII/GLiNER2 recall at 2–4× lower cost. *OpenMed PII SuperClinical Large (434M)* over both fields was the only model that clearly raised recall on our held-out adversarial synthetic set (40 encounters, 720 identifiers: 0.786 → 0.886, 95 % CI 0.861–0.907; precision 0.938 → 0.944). *MedicalGuard* vetoes person and organisation candidates that match ICD-10-CM eponyms, FDA drug names, clinical terms or the record's own ICD descriptions. Finally, a *dataset step* generalizes further any record whose (age band, sex, occupation category, ethnicity) combination is shared by fewer than three records.



3 Results

Three kinds of evidence (1) *Bosch feedback on an earlier build* (mid-term, before the hardening and the age-band default): privacy removal proportion 0.5918, ICD-10 F1 delta 0.0, medical concept recall 1.0. It is not a score of this release. (2) *Local evaluation*: fictional Synthea worlds with fixed denominators, and aggregate proxies on the 67-record eval split. (3) *Engineering acceptance tests* (§4).

Table 1. What the final hardening changed, on fictional data. The same synthetic encounters were anonymized by the code before and after the hardening, both with the age-band policy. dev1 and dev2 are two Synthea-generated

worlds of 300 encounters each; long1 holds 60 records of task-like length. Each cell reads *before* → *after* as count/total: blood pressure was kept exactly in 44 of 92 readings before, and in all 92 after.

Measure	dev1 (300 enc.)	dev2 (300 enc.)	long1 (60 long records)
Clinical content kept: higher is better			
Blood pressure kept exactly	44/92 → **92/92**	48/91 → **91/91**	18/47 → **47/47**
Section headers kept	2793/2806 → **2806/2806**	2717/2737 → **2737/2737**	1145/1163 → **1163/1163**
Diagnoses, medications and doses, durations	100 % kept, unchanged	100 %, unchanged	100 %, unchanged
Identifying details left in the output: lower is better			
Adults with a bare exact age answer	31 → **0**[a]	29 → **0**	28 → **0**[a]
Patients with ≥ 3 children: exact count visible	20/61 → **0/61**	31/54 → **0/54**	12/16 → **0/16**
Residual town (of encounters naming one)	5/104 → 3/104	8/103 → 4/103	2/42 → 1/42
Residual first / last name (unchanged)	4/162 · 3/261	2/156 · 3/251	2/52 · 0/60

[a] Excluding two `90+` answers, which are correctly top-coded. In the same comparison, the 12 fictional red-team probes went from 7/12 to **12/12** privacy and from 39/42 to **42/42** clinical assertions; the linkage attack is in Table 2.

Table 2. Why adult age bands are the default. Our synthetic re-identification benchmark (Synthea population, auxiliary registries, Splink attacker) measured success at a pool of 2,000 under the informed threat C, where the attacker already knows part of the diagnoses and event years:

Published text	Dev worlds (600 enc., not blind)	Blind world (300 enc., unseen population and phrasing)
Original	95.8 %	96.3 %
MedAnon, exact ages 0–89	38.2 %	34.3 %
MedAnon, adult age bands	21.5 %	20.3 %
MedAnon, age bands, hardened code	**11.7 %**	not measured

With public information only (threat A), success was 0.5 % (dev) and 0.0 % (blind) even with exact ages. An independent LLM adversary (local `qwen3.5:35b`, the 67 eval records) points the same way: the expected probability of singling out a patient fell from 0.063 on the original text to 0.034 with exact ages and 0.0042 with age bands. The two attackers model different threats, so we never combine their numbers.

The clinical information loss. Lab values become clinical intervals by design, and `EF [40-50]` straddles the HFrEF/HFmrEF cut-off. About 9–14 % of weights and heights a clinician needs exactly are still generalized on the Synthea worlds, because the exemptions are rules (paediatrics, weight-based dosing), not clinical understanding. In an earlier synthetic round, the body-measure step raised the generalized "must stay exact" heights from 10/40 to 20/40 and weights from 10/68 to 40/68 (the gold flag is partly inconsistent, but the risk is real). On the older build, a full human review of the masks (one annotator) found clinical content masked in 25 of the 67 eval encounters (52 of 518 masked spans). The hardening targets that mechanism; the deterministic audit now flags 3 records instead of 6.

4 Engineering and reproducibility

- **Tests.** 194 automated tests on synthetic data (unit, end-to-end, clinical boundaries, red-team regression); 194/194 pass on the GPU host with the production detectors.
- **Offline by construction.** With `--offline` nothing touches the network. If a configured model is missing, the run stops; it never falls back silently to a weaker pipeline.
- **Footprint.** Peak 2,639 MiB of VRAM including the CUDA context (measured on a 48 GB card; a physical 4 GB card was not tested), 3.64 GB of RAM; 0.26 s per record on GPU (0.79 s for long records), about 13.7 s on CPU.
- **Traceability.** Every run writes one audit line per decision, without original text, and a manifest with code, config and weight hashes, library versions and input/output hashes. Final eval output: 67/67 valid, 989 explained decisions, SHA-256 …; the dataset check reports 5/67 records below $k = 3$.

5 Bonus tasks

Bonus task	What we built	Evidence
Adversarial privacy attacks	two independent attackers: a Splink linkage benchmark with three threat models on synthetic worlds, one of them blind (Table 2), and a local LLM adversary (`qwen3.5:35b`) that extracts quasi-identifiers and tries to recover masked values	LLM adversary, 67 eval records, age bands: 7 of 98 masked identifiers recovered (7.1 %, 95 % CI 3.5–14.0); names 2/69, at chance level
Explainability	one explanation per decision, including kept medical look-alikes with a reason code; no original text in the audit	989/989 decisions explained on the final eval output
Efficiency	several profiles, from rules + spaCy without torch to the full stack; CPU or GPU	full stack: 0.26 s per record on GPU, 2,639 MiB VRAM, 3.64 GB RAM
Without ICD-10 codes	`--no-icd` removes the ICD context from the clinical veto	`standard` profile: 66/67 eval outputs identical with and without ICD context
Robustness to other inputs	synthetic Synthea worlds in other styles: 60 long-form records and a blind world with an unseen population and phrasing	Tables 1 and 2

How the LLM attacker works. An independent adversary plays an analyst who holds one anonymized record, US population statistics and a local LLM (`qwen3.5:35b`), but no identity database. One schema-constrained call extracts the patient's quasi-identifiers, each with a verbatim quote; code drops facts whose quote is not in the text, medical

content and restated ICD codes. The remaining facts are priced against population statistics to estimate the chance of singling the patient out, and a second call guesses what each placeholder hid. On an earlier build with age bands, no eval record stayed unique in the US population (0/67, against 4/67 originally).

6 Challenges and ideas that did not work

What we tried	What happened	What we did
GLiNER / GLiNER2 PII models	high synthetic recall, but on real text they relabelled `[doctor]` tags and common words as entities	uncased BERT cascade: same recall, 2–4× cheaper
A local LLM as detector (Qwen3.5-2B, Q4)	recall 0.781 against 0.769, at about 57 s per record on CPU	dropped; no generative model at inference
Healthcare-Brain-NER	recall 0.794, no clear gain	not used
Threshold-safe lab perturbation (±3 %)	stopped exact joins only: 70.6 % of tolerant lab links still succeeded	clinical intervals (11.8 %)
Exact ages 0–89, Safe-Harbor style	the largest linkage lever in our benchmark (38.2 % against 21.5 %)	adult decade bands
spaCy on vitals lines	"BP 114/71" tagged as an organisation: half the synthetic BP readings lost	statistical-span filters (Table 1)

7 Limitations and residual problems

- **Ambiguous surnames.** Surnames that are also common words ("waters", "marks") can survive a partial match: about 1–2 % of name mentions on synthetic data. The hardening did not change residual names (Table 1).
- **Places without a cue.** Towns mentioned without a residence cue can survive.
- **The clinical story is kept on purpose.** ICD-10 codes, event years and the visit year are linkage vectors. An attacker who already knows part of the history still re-identifies about 12 % of synthetic dev encounters.
- **Children.** Exact paediatric ages and children's birth years are kept because they matter clinically.
- **Not formal k-anonymity.** The $k = 3$ step covers four quasi-identifier types only; 5/67 eval records stay below $k = 3$.

8 Conclusion

In the encounters most of the identifying power sits in age, family, work, places and the clinical story, and the medical vocabulary is full of person-like words. We combined off-the-shelf models with parts built for this data: the note-guided truecasing of the dialogue, the name-dominance ratio, the ICD-aware clinical veto, the cross-field person registry, per-decision explanations, and a re-identification benchmark with three threat models that chose the policy. This let us make each trade-off deliberately, measure it on fixed denominators and explain every decision. It cannot make a rich clinical history anonymous on its own; we measured that residual risk and report it rather than hide it.

AI tools disclosure. We used Claude (Anthropic, through Claude Code) and other AI coding assistants extensively for implementation, tests, analysis and documentation, including drafts of this report. Their output was checked by the automated tests, controlled synthetic benchmarks and human review, and every number above traces to a script, test or manifest in the repository. The anonymizer uses no generative model; a local LLM appears only in the adversarial attack code (`attack/`).

Team. Matteo Marello (matteomarello3@gmail.com) · Paolo Pusterla (pusterlapaolo81@gmail.com) · Tommaso Riggio (tommy.riggio204@gmail.com) · Andrea Orione (andrea.orione02@gmail.com) · Valeria Intini (valeriaintini2001@gmail.com). Code released under the MIT licence. Evidence: `reports/FINAL_HARDENING.md`, `research/reid/`, `attack/paper/`.